

eman ta zabal zazu



Universidad
del País Vasco

Euskal Herriko
Unibertsitatea

SGSSI

IKER FERNÁNDEZ MOLANO

Pérdida de información

Por fallos de usuario (29%), Fallos de software, Fallos de hardware, robo o ataques y desastres ambientales

Backup

Duplicado de información por seguridad:

- Auditorías
- Historial de versiones
- Informática forense
- Restaurar información

ISO 27002:2017 → 12.3 ≡ UNE 71501

REGLA 3-2-1: 3 copias, 2 copias una offline y 1 en un lugar físico diferente

TIPOS

- ↳ Día-Cero: Copia al empezar a hacer modificaciones, pero en caso de recuperar se inicia desde el punto de partida
- ↳ Completa: Se realiza una copia de toda la información, ocupa mucho espacio
- ↳ Incremental: Se realiza una copia de los archivos modificados desde la última copia completa o incremental.
- ↳ Diferencial: Se realiza una copia de los archivos modificados desde la última copia completa.

PROTECCIÓN DE ATAQUES COPIAS

- ↳ Acceso al soporte
- ↳ Disponibilidad
- ↳ Protección
- ↳ Tiempo de vida del soporte

VAP Red insegura → Red segura o red interna

- ↳ Confidencialidad
- ↳ Integridad, hash
- ↳ No repudio

Hokey Pops → Sésvelo

HIDS → Detecta intrusiones en un host mediante análisis kernel, verificación integridad, auditorías y revisión de instalaciones

NETWORK IDS

- ↳ Vigilan el tráfico de la red
- IP/DOS spoofing
- SYN Flooding
- MAC-IP pairs

SEGURIDAD INTERNET

- ↳ Confidencialidad e Integridad de los datos
- ↳ Disponibilidad de la red
- ↳ Control de acceso para evitar ataques intrusivos y autenticación

DEFENSA PERIMETRAL

- ↳ Barrera entre red interna, menos restrictiva, y externa
- ↳ Controla el tráfico por un punto para monitorizarlo y filtrarlo
- ↳ Se permiten algunas conexiones

PROXY

- ↳ Intermediario
- ↳ Traduce IP a NAT
- ↳ El cliente hace peticiones de Proxy que las gestiona y las envía al servidor remoto

FIREWALL

- ↳ Filtra paquetes según la política predefinida por el administrador
- ↳ Oculta equipos e información ante ataques
- ↳ Limita el ancho de banda
- ↳ Dirige a DMZ → Se crea a partir de uno o dos firewalls, zona entre internet e intranet

ACL → Reglas de filtrado

TIPOS

- Dinámico → Tiene en cuenta Regla además de paquetes
- Passwela de aplicación → Tiene en cuenta datos, reglas de protocolo y sesión
- Política restrictiva → whitelist
- Política permisiva → blacklist

NO SE PUENE

Broadcast, Localhost, ICMP, ICMP Redirect, Paquetes < MIN, Direcciones int.

IPS → Sistema encargado de detectar y reaccionar automáticamente ante incidentes

- ↳ Motor de análisis: Analiza fuente de eventos basándose en la BBDD
- ↳ Motor de respuesta: Alarmas e informes

RESPUESTAS

- ↳ Activas: Anula TCP, reconfigurar firewall
- ↳ Pasivas: Genera informes

SEGURIDAD FÍSICA

Coherente, equilibradas y medidas aplicadas a los servicios

NOTIAS

- EN SCSO para Centro de Datos, estructura diseño, construcción y operación
- ISO 27001, sistemas de gestión de seguridad de la información. Mantenimiento, acceso...
- ISO 27002, cómo implementar ISO 27001
- ISO 27003, describe pasos para construir un SSSI
- ISO 27004, evaluar efectividad
- ISO 27005, identificación, evaluación y tratamiento de riesgos

PDCA

Plan → Qué hacer si pasa un desastre

Análisis de riesgos → Identificar amenazas, pérdidas y costes

Medidas → Técnicas (Backups), Organizativas (Seguros) y Humanas (Formación)

Subplanes → Respaldo (prevenir), Emergencia (reducir daños) y Recuperación (volver a la normalidad)

Do → Aplicar contramedidas

Check → Auditorías

Act → Meor o fue fallo y repetir

AMENAZAS

- Humanas: usuarios controlados y registrados, zonas críticas protegidas, control de acceso protegido
- Desastres naturales: Planificarlos, Pérdidas = datos + equipos + dinero, Resiliencia: capacidad de recuperarse rápido
- Entorno: Calor, polvo, insectos → refrigeración, limpieza, filtros
- Soporte físico: sólo en zonas seguras, revisiones, sólo cuando sea necesario

DEEP WEB

→ Deepnet (la que usamos): indexación 10%

Contenido no accesible directamente 90%

Información confidencial o protegida. No indexados. Info suelta, info no HTML, no censura, contenido ilegal.

NIVELES DESEPUES

N1: Conocidos y para todos los públicos

pu → N2: Desconocidos y pornográficos

N3: Necesita privacidad y anonimato

N4: Necesita proxy. Contenidos ilegales

N5: Secretos gubernamentales y militares

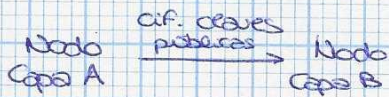
TOR (The onion Router)

Red navegación anónima, oculta origen y destino de los paquetes

- TOR Browser: navegador web

- Tails: SO desde USB

Conexión → Camino aleatorio



DELITOS INFORMÁTICOS (Convenio sobre ciberdelincuencia de la UE)

→ Relacionados con el contenido: Pornografía infantil, amenazas, calumnias, etc.

Calumnia: decir que alguien ha cometido un delito

Injuria: atacar contra dignidad de alguien

→ Relacionados con infracciones de derechos de autor: Propiedad intelectual, distribución copias ilegales películas... y reproducción programas protegidos

→ Relacionados con la informática: Datos no auténticos

→ Contra confidencialidad, integridad y disponibilidad de datos y sistemas informáticos: distribución virus, acceso ilícito a sistemas informáticos, etc.

CÓDIGO PENAL

LEY ORGÁNICA PROTECCIÓN DE DATOS DE CARÁCTER PERSONAL (LOPD)

El responsable debe: Documento seguridad actualizado, garantizar conocimiento normas de seguridad, auditorías, identificación, etc.

Principios: Habeas data: los datos pertenecen al usuario, calidad de los datos, seguridad de los datos, deber de secreto, informar recopilar datos, consentimiento, cesión sólo mismo nivel de protección y datos especialmente protegidos.

Derechos: Información, Acceso a sus datos, Rectificación y cancelación, oposición, intimidad

RGPD

Principios:

- Responsabilidad proactiva
- Protección desde el diseño
- Transparencia

Obligaciones:

- Avisar brechas $\leq 72h$
- Transferencias internacionales más controladas
- Multas altas
- Delegado de Protección de Datos (DPO)

Derechos del ciudadano:

- Información clara
- Derecho al olvido
- Portabilidad de datos
- Consentimiento explícito y revocable

INFORMÁTICA FORENSE

Disciplina criminalística que investiga sistemas informáticos $\rightarrow$ evidencias digitales.

Puede aplicarse en investigaciones privadas. Agentes de la ley, seguros, etc.

$\rightarrow$ Objetivos y Funciones

- Extraer información de un sistema
- Monitorizar
- Recuperar datos
- Detectar incumplimientos de políticas

$\rightarrow$ Principios Clave

- Locard: Todo contacto deja rastro
- Heisenberg: Medir un sistema lo altera

$\rightarrow$ Condiciones

- Respetar la ley
- Evitar modificaciones, eliminaciones o creaciones
- Mantener info exacta
- Reproducible

$\rightarrow$ Proceso

- Identificación. Identificar sistemas, notario, fotos, cadena de custodia, 1º info volátil, write blockers
- Conservación. Evitar pérdidas, documentar, original seguro
- Análisis. Recuperación de archivos, logs... línea temporal. Privacidad $\rightarrow$ key words
- Presentación. Explicar forme clara e imparcial, perito testifica o cuestionar a otros.